COMPTIA SECURITY+ SY0-701 | DOMAIN 5 · SECURITY PROGRAM MANAGEMENT AND OVERSIGHT (20%)

Security+ 5.1 · Security Considerations

Mestre CyberSec · **Lesson 5.1 — Security Considerations** (4:51) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Executive Lesson Summary: Regulatório: GDPR (UE), HIPAA (saúde), PCI-DSS (cartão), SOX (financeiro), FERPA (escola); Padrões Industriais: CIS Benchmarks, Família ISO (27001 ISMS, 27002 controles, 31000 ERM) e Família NIST: CSF (infraestrutura crítica), SP 800-53 (catálogo controles), SP 800-37 (RMF) e SP 800-30 (risco).

💡 Key Exam Highlights & Critical Concepts

- NIST CSF = infraestrutura crítica (Identify, Protect, Detect, Respond, Recover); SP 800-53 = catálogo de controles
- ISO 27001 = requisitos do SGSI/ISMS; ISO 27002 = código de práticas e controles de segurança
- Cada indústria tem sua LEI: PCI-DSS pagamento, HIPAA saúde, SOX financeiro, GDPR cidadãos da UE

🎯 Exam Tips & Typical CompTIA Scenarios

- 'framework for improving critical infrastructure cybersecurity'=NIST CSF
- 'standard specifically addressing an ISMS'=ISO 27001 / ISO 27002
- 'catalog of security and privacy controls for federal systems'=NIST SP 800-53

🚨 Beyond the Video: Official Exam Concepts, Protocols & Traps (Section 5.1 — Security Considerations)

Why is this advanced coverage required for SY0-701?: Video lectures provide foundational concepts, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

• General Data Protection Regulation (GDPR)

EU regulation that protects personal data of EU citizens/residents and applies to organizations anywhere that process their data.

⚠️ ***Exam Trap:*** *Questão citando 'dados de cidadãos da UE independente da localização da empresa' = GDPR.*

• Health Insurance Portability and Accountability Act (HIPAA)

U.S. law protecting protected health information (PHI) and requiring privacy and security safeguards in healthcare.

⚠️ ***Exam Trap:*** *Saúde, PHI, hospital ou seguradora nos EUA = HIPAA.*

• Payment Card Industry Data Security Standard (PCI-DSS)

Industry standard for organizations that store, process, or transmit cardholder data, with requirements to protect payment card data.

⚠️ ***Exam Trap:*** *Dados de cartão de crédito/débito = PCI-DSS; é padrão da indústria, não lei governamental.*

• Sarbanes-Oxley Act (SOX)

U.S. law imposing financial reporting, internal control, and record retention requirements on publicly traded companies.

⚠️ ***Exam Trap:*** *Empresa de capital aberto, relatórios financeiros ou controles internos = SOX.*

• Family Educational Rights and Privacy Act (FERPA)

U.S. law protecting privacy of student education records at institutions receiving federal funding.

⚠️ ***Exam Trap:*** *Registros acadêmicos, escola/universidade ou aluno = FERPA.*

• Center for Internet Security (CIS)

Organization that publishes CIS Controls and Benchmarks, prioritized security best practices for hardening systems and reducing cyber risk.

⚠ ***Exam Trap:*** *Controles priorizados, benchmarks de configuração ou hardening = CIS.*

• NIST Cybersecurity Framework (CSF) (NIST CSF)

A voluntary framework designed for improving critical infrastructure cybersecurity and managing organizational cyber risk through five core functions: Identify, Protect, Detect, Respond, and Recover (+ Govern).

⚠ ***Exam Trap:*** *Gatilho de prova: 'improving critical infrastructure cybersecurity' ou 'common framework integrating standards' = NIST CSF.*

• NIST SP 800-53 (Security & Privacy Controls)

Comprehensive catalog of security and privacy controls for federal information systems and organizations to protect operations and assets against diverse cyber threats.

⚠ ***Exam Trap:*** *Gatilho de prova: 'comprehensive catalog of security and privacy controls for federal systems' = NIST SP 800-53.*

• NIST SP 800-37 (Risk Management Framework - RMF)

Guidelines for applying the Risk Management Framework to federal systems, providing a disciplined, structured 7-step process for system authorization and lifecycle risk management.

⚠ ***Exam Trap:*** *Gatilho de prova: 'Risk Management Framework' ou 'disciplined process for system authorization and monitoring' = NIST SP 800-37 (RMF).*

• NIST SP 800-30 (Conducting Risk Assessments)

Special publication providing authoritative guidance on conducting risk assessments, determining likelihood, impact, threat sources, and vulnerability exposure.

⚠ ***Exam Trap:*** *Gatilho de prova: 'guidance for conducting risk assessments' = NIST SP 800-30. Não confundir com CSF ou 800-53.*

• ISO/IEC 27001 (ISMS Requirements) (ISO 27001)

International standard establishing the formal specification and audit requirements for an Information Security Management System (ISMS).

⚠ ***Exam Trap:*** *Gatilho de prova: 'ISO standard specifically addressing an ISMS for formal certification' = ISO 27001.*

• ISO/IEC 27002 (Information Security Controls) (ISO 27002)

A supporting standard that provides a code of practice and implementation guidance for information security controls referenced in ISO 27001.

⚠ ***Exam Trap:*** *Gatilho de prova: 'code of practice and implementation guidance for security controls' = ISO 27002.*

• ISO 27005 & ISO 31000 (Risk Management) (ISO 27005 / 31000)

ISO 27005 provides information security risk management guidance. ISO 31000 defines enterprise-wide risk management (ERM) across operational, financial, and strategic business domains.

⚠ ***Exam Trap:*** *Distinção CompTIA: ISO 27005 = risco em TI/segurança; ISO 31000 = risco corporativo global; ISO 9001 = qualidade de fabricação.*

🏛️ Conceptual Deep Dive, Real-World Analogies & GRC Analysis

📌 Regulatory & Statutory Compliance Factors

🏠 **Real-World Analogy:** Fire marshall codes and health inspection regulations enforced upon a pharmaceutical warehouse: you cannot shut off sprinkler systems or cut medicine refrigerator power to trim electric bills. Disobedience results in immediate business closure and revoked commercial operating permits.

🔍 **Root Cause & Background:** Organizations operate across multi-jurisdictional and highly regulated environments (healthcare, banking, children's privacy) where lax cybersecurity constitutes statutory civil and criminal law violations.

🛡️ **GRC Auditor Perspective:** Map corporate statutory obligation matrices (GDPR, HIPAA, LGPD, PCI-DSS) against operational security safeguards to prove continuous compliance to law enforcement and regulators.

⚠️ **How CompTIA Tests This:** Exam trigger: 'laws, industry mandates, and statutory rules that dictate security architecture decisions regardless of internal preferences' = Regulatory & Compliance Considerations.

📌 Legacy Systems & End-of-Life (EOL / EOSL)

🏠 **Real-World Analogy:** A 40-year-old vintage transport vehicle whose original factory has closed, with zero replacement parts or modern seatbelts available. If the brake cylinder ruptures, no official replacements exist. To operate it safely, you must restrict it to private closed tracks with specialized escorts.

🔍 **Root Cause & Background:** Vendors terminate maintenance lifecycles and cease releasing security patches, leaving legacy hardware and software exposed to permanent, unpatchable zero-day exploits.

🛡️ **GRC Auditor Perspective:** Maintain automated CMDB asset inventories tracking manufacturer EOL/EOSL timelines, enforce decommission roadmaps, and mandate network microsegmentation for unavoidable legacy gear.

⚠️ **How CompTIA Tests This:** Exam trigger: 'vendor no longer provides security updates, technical support, or bug fixes for an operating system' = End of Life (EOL) / End of Service Life (EOSL).

📌 Balancing Security with Usability & Business Operations

🏠 **Real-World Analogy:** Installing biometric retina scans, steel turnstiles, and bomb-proof blast doors at the entrance of a local corner bakery. The bakery becomes impregnable against bank robbers, but customer foot traffic drops to zero and bakers take 40 minutes to deliver a loaf of bread, bankrupting the company.

🔍 **Root Cause & Background:** Overly cumbersome security barriers hinder basic productivity, driving frustrated staff to establish Shadow IT channels (unapproved personal cloud storage) to bypass friction.

🛡️ **GRC Auditor Perspective:** Conduct user friction assessments for new controls, monitor CASB telemetry for Shadow IT surges, and run stakeholder operational reviews to ensure security enables business velocity.

⚠️ **How CompTIA Tests This:** Exam trigger: 'employees bypass complicated VPN authentication by sending confidential spreadsheets to personal Dropbox accounts' = Poor Usability leading to Shadow IT.

📌 The NIST Publication Hierarchy: CSF vs SP 800-53 vs SP 800-37 vs SP 800-30

🏠 **Real-World Analogy:** The architectural design, procurement, and legal licensing of a secure federal facility: 1) NIST CSF is the high-level executive building concept (perimeter fence, vault, guards, alarm system) structured into core functions; 2) NIST SP 800-53 is the engineering materials procurement catalog (specifying exact steel alloy, lock tolerances, and reinforced glass thickness); 3) NIST SP 800-37 (RMF) is the multi-step municipal licensing process (categorize, assess, issue formal Authority to Operate); 4) NIST SP 800-30 is the actuarial fire-risk calculation methodology.

🔍 **Root Cause & Background:** NIST CSF originated from Executive Order 13636 ('Improving Critical Infrastructure Cybersecurity') to establish a voluntary, shared risk lexicon across public and private sectors. NIST Special Publications (SP 800 series) deliver prescriptive compliance frameworks mandated for federal agencies under FISMA.

🛡️ **GRC Auditor Perspective:** GRC auditors verify whether the firm benchmarks against the voluntary NIST CSF tiers or is contractually obligated to demonstrate compliance against the granular control baseline catalog of NIST SP 800-53.

⚠️ **How CompTIA Tests This:** Crucial CompTIA triggers: 'framework for improving critical infrastructure cybersecurity' / 'common framework integrating standards' = NIST CSF. 'Catalog of security and privacy controls for federal systems' = NIST SP 800-53. 'Risk Management Framework / authorization lifecycle' = NIST SP 800-37. 'Conducting risk assessments' = NIST SP 800-30.

📌 The ISO Standards Ecosystem: 27001 vs 27002 vs 27005 vs 31000 vs 9001

🏠 **Real-World Analogy:** Corporate accreditation tiers: 1) ISO 27001 is the certified ISMS diploma hung on the executive wall following rigorous external audit; 2) ISO 27002 is the engineering code of practice manual explaining how to configure controls; 3) ISO 27005 is the IT-specific risk assessment playbook; 4) ISO 31000 is enterprise-wide risk management covering financial, legal, and operational perils; 5) ISO 9001 is factory assembly-line quality management.

🔍 **Root Cause & Background:** Global enterprises demand standardized verification of security governance. ISO 27001 specifies auditable ISMS certification criteria, while ISO 27002 details implementation mechanics for the referenced controls.

🛡️ **GRC Auditor Perspective:** International auditors evaluate governance against mandatory ISO 27001 clauses and assess operational control effectiveness leveraging ISO 27002 recommendations.

⚠️ **How CompTIA Tests This:** ISO Exam triggers: 'standard specifically addressing an ISMS for certification' = ISO 27001 (or 27002 as the control code of practice). 'Enterprise-wide risk management' = ISO 31000. 'IT security risk management' = ISO 27005. 'Quality management' = ISO 9001.

⚡ QUICK-REFERENCE EXAM CHEAT SHEET

Typical Exam Scenario / Practical Situation	Technical Concept & Target Answer
Hospital must refactor its database architecture to strictly satisfy federal health information privacy statutes	**Regulatory Consideration / HIPAA**
Enterprise formally implements Govern, Identify, Protect, Detect, Respond, Recover to structure its security posture	**NIST Cybersecurity Framework (NIST CSF)**
Firewall manufacturer issues an announcement that firmware version 4.2 will receive no further patches or security hotfixes	**End of Life / End of Service Life (EOL / EOSL)**
Sales department escalates that four-factor authentication prompts every fifteen minutes are severely halting revenue operations	**Security vs Usability Friction**
Mission-critical manufacturing robotic unit cannot be patched; engineer isolates it within an air-gapped industrial VLAN	**Compensating Control for Legacy Asset**
Staff adopts unauthorized consumer messaging apps because corporate communication tools block sharing PDFs with clients	**Shadow IT via Operational Blocks**
A US federal agency must adopt a common framework for improving critical infrastructure cybersecurity integrating industry standards	**NIST Cybersecurity Framework (NIST CSF)**
Comprehensive catalog of security and privacy controls for federal information systems and organizations	**NIST SP 800-53**
Structured 7-step lifecycle methodology to categorize, assess, authorize, and continuously monitor federal IT systems	**NIST SP 800-37 (Risk Management Framework - RMF)**
Prescriptive guidance and methodology for conducting rigorous risk assessments across organizational IT systems	**NIST SP 800-30**
Organization pursues international certification demonstrating its Information Security Management System (ISMS) follows global best practices	**ISO/IEC 27001 (and ISO/IEC 27002 for controls catalog)**
Board seeks to institute enterprise risk management across finance, human resources, brand reputation, and physical operations	**ISO 31000 (Enterprise Risk Management - ERM)**

✅ Authentic Practice Questions (10 Real Exam Scenarios)

Scenario-based exam questions. Complete explanations and distractor analysis are provided in the answer key below.

QUESTION 1 · EXAM SCENARIO

A European online retailer discovers that a former employee in Germany still has access to customer records containing names, addresses, and purchasing history. The security team must report the potential exposure of EU citizens' personal data within 72 hours. Which regulatory framework specifically imposes this notification deadline?

A) HIPAA Breach Notification Rule

B) PCI-DSS Requirement 12.10

C) GDPR Article 33

D) SOX Section 404

QUESTION 2 · EXAM SCENARIO

A hospital's IT administrator is implementing controls to protect electronic Protected Health Information (ePHI) stored on a new file server. The administrator needs to ensure safeguards for confidentiality, integrity, and availability of health data. Which US federal regulation defines these specific safeguards?

A) Health Insurance Portability and Accountability Act (HIPAA) Security Rule

B) Sarbanes-Oxley Act (SOX) to ensure third-party supplier accountability and oversight

C) Payment Card Industry Data Security Standard (PCI-DSS) in accordance with documented business impact analysis criteria

D) Family Educational Rights and Privacy Act (FERPA) to satisfy external independent certification audit controls

QUESTION 3 · EXAM SCENARIO

A small e-commerce company processes approximately 500 credit card transactions per month and stores the cardholder data in a flat database file. A security consultant must recommend the standard that defines how this data should be protected during storage and transmission. Which compliance framework applies?

A) GDPR to ensure third-party supplier accountability and oversight

B) PCI-DSS (Payment Card Industry Data Security Standard)

C) SOX to satisfy external independent certification audit controls

D) FERPA while preserving chain of custody and forensic integrity

QUESTION 4 · EXAM SCENARIO

A publicly traded company's CFO is concerned about the accuracy of financial statements being submitted to the SEC. The IT security team must implement controls ensuring the integrity of financial reporting systems and audit trails. Which regulation directly governs these requirements for public companies?

A) HIPAA in accordance with documented business impact analysis criteria

B) PCI-DSS to satisfy external independent certification audit controls

C) GDPR Article 32 while preserving chain of custody and forensic integrity

D) Sarbanes-Oxley Act (SOX) Section 404

QUESTION 5 · EXAM SCENARIO

A university experiences a data breach where an attacker accesses student records including grades, disciplinary files, and Social Security numbers. Parents are demanding to know why their children's educational records were not protected. Which US regulation specifically governs the protection of student education records?

A) Family Educational Rights and Privacy Act (FERPA)

B) HIPAA Privacy Rule while preserving chain of custody and forensic integrity

C) PCI-DSS under formally agreed service level and operating agreements

D) SOX to demonstrate legally defensible due diligence and due care

QUESTION 6 · EXAM SCENARIO

A multinational corporation is adopting a security framework that provides prioritized, actionable, and prescriptive guidance for cybersecurity risk mitigation. The CISO wants a framework that maps security controls to specific implementation levels based on organizational maturity. Which industry framework best fits this requirement?

A) GDPR while preserving chain of custody and forensic integrity

B) HIPAA under formally agreed service level and operating agreements

C) CIS Critical Security Controls (CIS Controls)

D) PCI-DSS in compliance with statutory privacy and data protection mandates

QUESTION 7 · EXAM SCENARIO

An organization is pursuing ISO certification to demonstrate to European customers that its Information Security Management System (ISMS) follows internationally recognized best practices. The auditor will assess the company's systematic approach to managing sensitive information. Which ISO standard specifically addresses an ISMS?

A) ISO 27005

B) ISO 31000

C) ISO 9001 in compliance with statutory privacy and data protection mandates

D) ISO 27002

QUESTION 8 · EXAM SCENARIO

A US federal agency must adopt a common framework for improving critical infrastructure cybersecurity. The CIO has published guidance that integrates industry standards, guidelines, and best practices to help organizations manage cybersecurity risk. Which NIST publication provides this comprehensive cybersecurity framework?

A) NIST SP 800-53 to demonstrate legally defensible due diligence and due care

B) NIST Cybersecurity Framework (CSF)

C) NIST SP 800-37 (Risk Management Framework)

D) NIST SP 800-30 to comply with mandatory regulatory governance standards

QUESTION 9 · EXAM SCENARIO

A forensic investigator arrives at a crime scene where a server contains potential evidence of financial fraud. The investigator notes that the server is still running and connected to the network. To preserve the integrity and admissibility of evidence, what is the MOST appropriate first action?

A) Document the state of the system and capture volatile memory before shutting down

B) Immediately power off the server to stop all running processes to provide defensible quantitative risk metrics for leadership

C) Connect an external drive and copy all files immediately to comply with mandatory regulatory governance standards

D) Restore the system from the most recent backup within established organizational risk appetite thresholds

QUESTION 10 · EXAM SCENARIO

A marketing analyst at a multinational firm receives a request from a German customer to delete all personal information the company has collected about them, including browsing history, purchase records, and email correspondence. Which regulation grants the customer this specific right?

A) PCI-DSS Right to Erasure to provide defensible quantitative risk metrics for leadership

B) HIPAA Right to be Forgotten to comply with mandatory regulatory governance standards

C) SOX Right to Deletion within established organizational risk appetite thresholds

D) GDPR Right to Erasure (Article 17)

ANSWER KEY & COMPREHENSIVE DISTRACTOR EXPLANATIONS

Question 1: Option C — GDPR Article 33

GDPR Article 33 mandates that the supervisory authority be notified of a personal data breach within 72 hours of becoming aware of it. HIPAA applies to US healthcare, PCI-DSS to cardholder data, and SOX to financial reporting controls. The scenario's EU jurisdiction and 72-hour window are signature elements of GDPR.

Question 2: Option A — Health Insurance Portability and Accountability Act (HIPAA) Security Rule

The HIPAA Security Rule (45 CFR Part 160 and Subparts A and C of Part 164) establishes national standards to protect electronic PHI. It mandates administrative, physical, and technical safeguards ensuring confidentiality, integrity, and availability (the CIA triad). SOX covers financial reporting, PCI-DSS covers cardholder data, and FERPA covers student education records.

Question 3: Option B — PCI-DSS (Payment Card Industry Data Security Standard)

PCI-DSS applies to any entity that stores, processes, or transmits cardholder data, regardless of transaction volume. The standard defines requirements for encrypted transmission, access control, and secure storage of the Primary Account Number (PAN). GDPR covers EU personal data broadly, SOX covers financial reporting, and FERPA covers student records.

Question 4: Option D — Sarbanes-Oxley Act (SOX) Section 404

SOX Section 404 requires public companies to establish internal controls and procedures for financial reporting, including IT general controls that ensure the integrity of systems producing financial data. Section 802 specifically requires retention of audit-related records for seven years. HIPAA, PCI-DSS, and GDPR do not address financial statement integrity for public companies.

Question 5: Option A — Family Educational Rights and Privacy Act (FERPA)

FERPA (20 U.S.C. § 1232g) protects the privacy of student education records, granting parents certain rights regarding access and disclosure of personally identifiable information from education records. It applies to all schools receiving federal financial aid. The scenario's mention of student records (grades, disciplinary files) is a hallmark FERPA scenario, distinguishing it from healthcare (HIPAA) or financial regulations.

Question 6: Option C — CIS Critical Security Controls (CIS Controls)

The CIS Critical Security Controls (formerly SANS Top 20) provide a prioritized set of actions organized into Implementation Groups (IG1, IG2, IG3) based on organizational size and maturity. The framework is widely adopted as a prescriptive cybersecurity standard. GDPR and HIPAA are regulations with compliance requirements, and PCI-DSS focuses on payment card data only.

Question 7: Option D — ISO 27002

ISO/IEC 27002 provides the code of practice for information security controls and is commonly used in conjunction with ISO 27001 for ISMS implementation. Note: ISO 27001 specifies the ISMS requirements, but ISO 27002 (originally ISO 17799) provides the detailed control catalog. ISO 27005 focuses on risk management methodology, ISO 31000 is enterprise risk management, and ISO 9001 is quality management. The most accurate answer given the options is ISO 27002 for the controls.

Question 8: Option B — NIST Cybersecurity Framework (CSF)

The NIST Cybersecurity Framework (CSF) provides a policy framework of computer security guidance for how private sector organizations can assess and improve their ability to prevent, detect, and respond to cyber attacks. The CSF core functions are Identify, Protect, Detect, Respond, and Recover. NIST SP 800-53 is the controls catalog for federal systems, SP 800-37 is the RMF, and SP 800-30 is risk assessment guidance.

Question 9: Option A — Document the state of the system and capture volatile memory before shutting down

Proper forensic procedure requires following the order of volatility: capture volatile memory (RAM, network connections, running processes) first, then document the system's state, and only then consider controlled shutdown. Powering off immediately destroys volatile evidence such as running processes, network connections, and memory contents. The investigator must also maintain the chain of custody and use write-blockers for disk imaging.

Question 10: Option D — GDPR Right to Erasure (Article 17)

GDPR Article 17 establishes the 'Right to Erasure' (also called 'Right to be Forgotten'), allowing EU data subjects to request deletion of their personal data when certain conditions are met (e.g., data no longer necessary for original

purpose, consent withdrawn). PCI-DSS, HIPAA, and SOX do not grant consumers such deletion rights over their data. Only GDPR provides this specific right among the listed options.